

NIST CSF 2.0 GAP ANALYSIS

Cova Funds

NIST Cybersecurity Framework Version 2.0

Confidential | February 2026

Prepared by

Nancy Okereke

Cybersecurity Analyst | GRC | Threat Analysis

nancyokereke@outlook.com

1. Introduction

This report presents a cybersecurity gap analysis for Cova Funds, a fintech company offering mobile payments, wallet services, and small business lending across African markets. The assessment evaluates Cova Funds' current cybersecurity posture against the NIST Cybersecurity Framework (CSF) Version 2.0, published by the National Institute of Standards and Technology in 2024.

The purpose of this gap analysis is to identify areas where Cova Funds' current cybersecurity practices fall short of the NIST CSF 2.0 framework, and to provide actionable recommendations to strengthen its overall security posture. As a fintech handling sensitive customer financial data, a robust cybersecurity framework is both a regulatory expectation and a business necessity.

2. Company Overview

Company Name	Cova Funds
--------------	------------

Industry	Fintech
Services	Mobile payments, wallet services, small business lending
Employees	50
Operating Regions	Nigeria (with planned expansion to Ghana and Kenya)
Data Processed	Customer PII, BVN, transaction records, employee records
Framework Applied	NIST Cybersecurity Framework (CSF) 2.0

3. NIST CSF 2.0 Overview

The NIST Cybersecurity Framework 2.0 is a globally recognised voluntary framework that helps organisations manage and reduce cybersecurity risk. Version 2.0, released in 2024, expanded the original framework by adding a sixth core function – Govern – placing cybersecurity governance and leadership accountability at the centre of the framework.

The six core functions of NIST CSF 2.0 are:

Function	Abbreviation	Description
Govern	GV	Establishes cybersecurity risk management strategy, policies, roles, and oversight at leadership level. New in CSF 2.0.
Identify	ID	Understand the organisation’s assets, risks, and cybersecurity risk management context.
Protect	PR	Implement safeguards to manage cybersecurity risks and limit the impact of potential incidents.
Detect	DE	Identify the occurrence of cybersecurity events through continuous monitoring and anomaly detection.
Respond	RS	Take action regarding a detected cybersecurity incident to contain its impact.
Recover	RC	Restore capabilities and services impaired by a cybersecurity incident in a timely manner.

4. Gap Analysis Findings

The following assessment evaluates Cova Funds’ current cybersecurity posture against each of the six NIST CSF 2.0 functions. Each function is rated as Implemented, Partial, or Gap based on observed practices within the organisation.

4.1 Govern (GV)

Status	✖ Gap
Key Requirements	Cybersecurity strategy defined at leadership level; assigned cybersecurity roles and responsibilities; risk management policies documented; supply chain risk governance; compliance obligations tracked.
Current State	Cova Funds has no formal cybersecurity governance structure. Cybersecurity responsibilities are not formally assigned at the leadership level. No documented cybersecurity strategy, risk management policy, or compliance tracking process exists.
Gap	Absence of governance means cybersecurity decisions are reactive and ad hoc, with no accountability structure to drive consistent risk management across the organisation.

4.2 Identify (ID)

Status	⚠ Partial
Key Requirements	Comprehensive asset inventory; risk assessment process; risk management strategy; supply chain and third-party risk identification.
Current State	Cova Funds has an informal awareness of its key assets including customer data, employee devices, and the mobile app. However, no formal asset inventory, risk register, or documented risk assessment process is in place.
Gap	Without a formal asset inventory and risk register, Cova Funds cannot systematically prioritise cybersecurity investments or demonstrate risk awareness to regulators or auditors.

4.3 Protect (PR)

Status	⚠ Partial
Key Requirements	Identity and access management; security awareness training; data security controls; platform security; technology infrastructure resilience.
Current State	Basic access controls are likely in place for core systems. However, no formal security awareness training programme exists, device encryption is not enforced, Multi-Factor Authentication (MFA) is not consistently applied, and no formal data security policy has been documented.
Gap	Existing protections are informal and inconsistently applied. Without formal policies and training, employees remain a significant vulnerability, particularly to phishing and social engineering attacks.

4.4 Detect (DE)

Status	✖ Gap
Key Requirements	Continuous monitoring of systems and networks; anomaly and event detection; defined processes for analysing detected events.

Current State	Cova Funds has no SIEM (Security Information and Event Management) tool, no network monitoring capability, and no formal process for detecting and analysing suspicious activity across its systems.
Gap	Without detection capabilities, security incidents may go unnoticed for extended periods, significantly increasing the potential damage from a breach and complicating regulatory breach notification obligations.

4.5 Respond (RS)

Status	✖ Gap
Key Requirements	Documented incident response plan; defined roles for incident response; communication procedures; incident analysis and containment processes.
Current State	No formal incident response plan exists. There are no defined roles, escalation procedures, or communication templates for responding to a cybersecurity incident. Response to incidents would currently be entirely ad hoc.
Gap	Without a response plan, Cova Funds risks prolonged incident impact, regulatory non-compliance (NDPC requires breach notification within 72 hours), and reputational damage from poorly managed incidents.

4.6 Recover (RC)

Status	✖ Gap
Key Requirements	Incident recovery plan; business continuity planning; disaster recovery procedures; post-incident review and lessons learned process.
Current State	Cova Funds has no business continuity plan, no disaster recovery procedures, and no documented process for restoring operations following a cybersecurity incident. Data backups are not formally managed or tested.
Gap	A significant incident such as ransomware, DDoS, or data loss could result in prolonged service outage with no structured path to recovery, risking permanent loss of customer trust and business viability.

5. Gap Analysis Summary

#	Function	Abbreviation	Status	Priority	Timeline
1	Govern	GV	✖ Gap	Critical	30 days
2	Identify	ID	⚠ Partial	High	30 days
3	Protect	PR	⚠ Partial	High	45 days
4	Detect	DE	✖ Gap	Critical	60 days

#	Function	Abbreviation	Status	Priority	Timeline
5	Respond	RS	✗ Gap	Critical	30 days
6	Recover	RC	✗ Gap	High	90 days

6. Recommendations

6.1 Govern — Establish a Cybersecurity Governance Structure

- Appoint a senior leader accountable for cybersecurity risk management at the executive level.
- Develop and document a formal cybersecurity strategy aligned with business objectives.
- Define and communicate cybersecurity roles and responsibilities across all departments.
- Establish a risk management policy and a process for tracking regulatory compliance obligations.

6.2 Identify — Build a Formal Asset and Risk Inventory

- Conduct a comprehensive asset inventory covering all people, data, systems, and physical assets.
- Develop and maintain a formal risk register documenting identified threats, likelihood, impact, and risk scores.
- Implement a third-party risk identification process to assess supply chain and vendor risks.
- Review and update the asset inventory and risk register at least annually or after major changes.

6.3 Protect — Formalise and Strengthen Security Controls

- Enforce Multi-Factor Authentication (MFA) across all systems that handle customer or financial data.
- Implement full disk encryption on all employee devices.
- Launch a mandatory security awareness training programme for all staff, with phishing simulation exercises.
- Document and enforce a formal data security policy covering access control, device usage, and data handling.

6.4 Detect — Implement Continuous Monitoring Capabilities

- Deploy a SIEM tool (e.g. Splunk or Microsoft Sentinel) to centralise log collection and enable real-time threat detection.
- Implement network monitoring to detect anomalous traffic patterns and unauthorised access attempts.

- Configure automated alerts for critical security events such as failed login attempts, unusual data transfers, and API anomalies.
- Establish a formal process for analysing and escalating detected security events.

6.5 Respond — Develop an Incident Response Plan

- Create a formal Incident Response Plan (IRP) covering detection, containment, eradication, and recovery steps.
- Define incident response roles and assign named individuals responsible for each stage of the response process.
- Develop communication templates for notifying regulators (NDPC within 72 hours), customers, and leadership.
- Conduct tabletop exercises at least twice a year to test and improve the incident response plan.

6.6 Recover — Build Business Continuity and Disaster Recovery Capabilities

- Develop a Business Continuity Plan (BCP) defining how Cova Funds will maintain critical operations during a cybersecurity incident.
- Implement and document a Disaster Recovery Plan (DRP) with clear recovery time objectives (RTO) and recovery point objectives (RPO).
- Establish automated, encrypted data backups with regular restoration testing to verify backup integrity.
- Conduct a post-incident review after every significant security event to capture lessons learned and update recovery procedures.

7. Conclusion

This NIST CSF 2.0 gap analysis reveals that Cova Funds faces significant cybersecurity maturity gaps across four of the six framework functions — Govern, Detect, Respond, and Recover — with partial implementation in Identify and Protect. As a fintech company processing sensitive customer financial data across multiple African markets, these gaps represent material risk to the organisation's operations, regulatory standing, and customer trust.

Addressing these gaps is a strategic priority. The recommendations in this report provide a structured, prioritised roadmap for Cova Funds to build a resilient cybersecurity programme aligned with international best practice. Cova Funds is strongly advised to begin implementation immediately, starting with governance and incident response, and to conduct a follow-up assessment within six months to measure progress.